

SENTINAL SECURITY ASSESSMENT REPORT

Project: FinTech Payments API | Type: COMBINED | Date: 2026-09-03 06:37 UTC

Overall Risk Score	Critical	High	Medium	Low	Total Findings
87.3/100	1	1	5	11	18

1. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:** CRITICAL POSTURE**

The automated assessment of <https://ginandjuice.shop> identified immediate critical exposures requiring urgent remediation. A total of 18 findings were recorded, including 1 Critical and 1 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 18 (Critical: 1, High: 1, Medium: 5, Low: 11)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Session Management, Vulnerable Dependency, Cloud Credentials, Injection

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

3. Findings Inventory

Sev	Source	Vulnerability	Location / Remediation
HIGH	SAST	Potential SQL Injection via Unsanitized Query Execution Constructing SQL queries using string formatting, interpolation, or dynamic query variables without parameterized bindin	src/auth.py Fix: Use parameterized queries (e.g. <code>`cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`</code>) o
MEDIUM	SCA	Vulnerable Dependency: lodash (4.17.15) - GHSA-29mw-wpgm-hmr9 Vulnerability in lodash	package.json Fix: Upgrade lodash to a secure version. Upgrade to latest version.
MEDIUM	SCA	Vulnerable Dependency: django (3.2.0) - GHSA-2gwj-7jmv-h26r Vulnerability in django	requirements.txt Fix: Upgrade django to a secure version. Upgrade to latest version.
CRITICAL	SECRETS	Exposed Secret: AWS Access Key ID Hardcoded secret token or credential (GitHub Personal Access Token) found in source code repository.	src/auth.py Fix: Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/ Fix: Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.

LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/blog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/about <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/my-account <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/login <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/cart <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product/stock <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.

MEDIUM	DAST	Missing Clickjacking Defense (X-Frame-Options / CSP frame-ancestors) The target web page does not enforce frame embedding restrictions, leaving users vulnerable to UI redressing (Clickjacki	/catalog/product/stock <i>Fix:</i> Set `X-Frame-Options: DENY` or `Content-Security-Policy: frame-ancestors 'none'`.
MEDIUM	WEB	Missing HTTP Strict Transport Security (HSTS) Header The HSTS header forces web browsers to communicate exclusively over encrypted HTTPS, mitigating SSL-stripping and man-in	/ <i>Fix:</i> Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS re
MEDIUM	WEB	Missing Content Security Policy (CSP) Header A Content Security Policy restricts sources of executable scripts, stylesheets, and frames, preventing Cross-Site Script	/ <i>Fix:</i> Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; ob
LOW	WEB	Missing X-Content-Type-Options Header Setting `X-Content-Type-Options: nosniff` prevents browsers from MIME-sniffing a response away from the declared content	/ <i>Fix:</i> Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser A
LOW	WEB	Missing Referrer-Policy Header The Referrer-Policy header controls how much referrer information (sent via the Referer header) should be included with	/ <i>Fix:</i> Configure `Referrer-Policy: strict-origin-when-cross-origin` or `no-referrer`.